
Sécurité et administration

CER | Sécurité et Filtrage

Mardi 02 décembre 2025

TABLE DES MATIÈRES

AAV	2
Étude de cas: Sécurité et filtrage	2
Mots clés	2
Contexte	2
Problématique	3
Contraintes	3
Généralisation	3
Livrables	3
Pistes de solutions	3
Plan d'action	4
Démarche : Sécurité et filtrage	5
Définition: Mots clés	5
Corbeille: Sécurité et filtrage	8
Configuration nécessaire	8
PARTIE 1 - Administration déléguée du pare-feu	9
Analyse et résolution: Sécurité et filtrage	12
Analyser l'architecture existante de BERRIA et situer la DMZ	12
Faire l'inventaire des ACL	13
Déterminer les ACL nécessaire	16
Lister les flux réseaux requis	20
Définir les règles de filtrage (ACL) nécessaires sur le pare-feu.	23
Configurer le rôle du Proxy dans l'infrastructure.	27
Évaluer les risques et l'impact sur la DMZ	31
Conclusion	36
Capitalisation	37
Questions de validation	38
Ressources	40

- 4 Analyser de manière holistique la sécurité du S.I.
- 2 Expliquer le principe de Zone Démilitarisée (DMZ)
- 4 Sélectionner le filtrage réseau adapté
- 3 Administrer un proxy
- 1 Rappeler le cadre légal
- 3 Préparer et configurer un pare-feu
- 3 Relier les outils de sécurité à l'annuaire du S.I.

ÉTUDE DE CAS: SÉCURITÉ ET FILTRAGE

MOTS CLÉS

- IDPS
- DMZ
- Proxy
- Pare-feu
- UTM
- ACL
- DDoS
- PSSI
- SOC
- IDS/IPS
- Filtrage
- Vecteur d'attaque

CONTEXTE

Léo travaille actuellement sur un projet de sauvegarde et de sécurisation des données vers le Cloud. L'arrivée d'un technicien réseau pour installer un nouveau pare-feu

avec IDPS et un proxy l'amène à réfléchir à l'impact de son projet sur la DMZ, les règles de filtrage et la PSSI du SI.

PROBLÉMATIQUE

Comment améliorer la sécurisation des flux de données entre le SI, la DMZ et le Cloud tout en garantissant un filtrage réseau adapté et l'efficacité du proxy et du pare-feu ?

CONTRAINTES

- Infrastructure
- Respect de la PSSI
- Déployer un nouveau pare-feu
- IDS-IPS

GÉNÉRALISATION

- Sécurité Réseau
- Filtrage Réseau

LIVRABLES

- Rapport intégrant la partie de filtrage (ACL, architecture), le pare-feu, proxy
- Déterminer la DMZ et la mettre en place

PISTES DE SOLUTIONS

- Architecture Réseau
- Filtrage
- Logique ACL
- Rôles spécifiques d'un Pare-feu, d'un Proxy et d'un IDPS/UTM.
- Cadre légal

PLAN D'ACTION

- Définir les mots clés (DMZ, Proxy, Firewall, IDPS, etc.).
- Analyser l'architecture existante de BERRIA et situer la DMZ.
- Faire l'inventaire des ACL
- Déterminer les ACL nécessaire
- Lister les flux réseaux requis pour le projet Cloud/Sauvegarde (ports TCP/UDP).
- Définir les règles de filtrage (ACL) nécessaires sur le pare-feu.
- Configurer le rôle du Proxy dans l'infrastructure.
- Évaluer les risques et l'impact sur la DMZ
- Rédiger la partie filtrage du rapport et compléter l'exercice "Corbeille".

DÉMARCHE : SÉCURITÉ ET FILTRAGE

DÉFINITION: MOTS CLÉS

IDPS (Intrusion Detection and Prevention System):

Un IDPS est un système chargé de détecter et, si nécessaire, de bloquer en temps réel les tentatives d'intrusion ou les comportements anormaux dans un réseau. Il s'appuie à la fois sur des signatures (attaques connues) et sur l'analyse comportementale (écarts par rapport à la norme).

L'IDS observe et alerte, tandis que l'IPS peut intervenir directement en coupant ou modifiant le trafic. Bien positionné dans l'architecture réseau, un IDPS permet de repérer précocement les phases de reconnaissance, les exfiltrations et les attaques actives.

DMZ (DeMilitarized Zone):

La DMZ est une zone tampon située entre Internet et le réseau interne. On y place les services destinés au public (site web, serveur mail, DNS, portail VPN) afin qu'une compromission éventuelle n'ouvre pas la porte au reste du système d'information.

L'idée centrale est le cloisonnement strict : les flux sont limités et contrôlés, et la DMZ agit comme un espace séparé qui protège le cœur du réseau.

Proxy:

Un proxy est un serveur intermédiaire qui gère les communications entre les utilisateurs internes et Internet. Il peut filtrer l'accès à certains sites, mettre en cache les contenus pour optimiser les performances, appliquer des politiques de sécurité, enregistrer les actions et masquer les adresses internes.

C'est un point de contrôle essentiel pour encadrer et surveiller la navigation web.

Pare-feu (Firewall):

Le pare-feu est l'outil central de la défense périmétrique. Il contrôle les flux réseau selon des règles précises : adresses IP, ports, protocoles et parfois types d'applications. Les pare-feux modernes (NGFW) inspectent aussi le contenu des paquets, intègrent le contrôle applicatif, le VPN ou encore des mécanismes de prévention d'intrusions.

Un firewall efficace est celui dont les règles sont claires, limitées et régulièrement maintenues.

1. Pare-feu de filtrage (niveau réseau / packet-filtering, stateless ou stateful):

Un pare-feu de filtrage opère principalement sur les en-têtes réseau : adresses IP, ports et protocoles. - Stateless : examine chaque paquet indépendamment (rapide, simple, moins contextuel). - Stateful : conserve l'état des connexions (suivi des sessions TCP/UDP), autorise les réponses légitimes et bloque les paquets hors contexte. Avantages : faible latence, simple à déployer. Limites : visibilité limitée au contenu, moins efficace contre attaques applicatives.

2. Pare-feu applicatif (niveau application / proxy ou NGFW):

Travaille au niveau applicatif (HTTP, SMTP, DNS, etc.) : peut analyser le contenu, les URLs, les en-têtes applicatifs et effectuer inspection SSL/TLS, DLP, contrôle d'applications et filtrage par utilisateur. Les NGFW intègrent IDS/IPS, antivirus et fonctions de proxys. Avantages : contrôle granulaire, meilleure détection des menaces applicatives et exfiltration. Limites : plus coûteux, impact sur la latence et nécessité de gestion des certificats pour l'inspection TLS.

Solutions commerciales pour pare-feu

- Palo Alto Networks
- Fortinet (FortiGate)
- Check Point
- Cisco Firepower
- Juniper SRX
- pfSense / OPNsense (open-source)

UTM (Unified Threat Management):

Un UTM regroupe dans un seul équipement plusieurs fonctions de sécurité : pare-feu, IPS, antivirus, filtrage web, gestion VPN, anti-spam, etc. Cette approche simplifie la gestion et offre une vision unifiée de la sécurité.

L'inconvénient est qu'un UTM concentre tous les services critiques : s'il tombe, tout tombe. Il peut aussi devenir un goulot d'étranglement si on active trop de modules.

ACL (Access Control List):

Une ACL est une liste de règles permettant d'autoriser ou de refuser l'accès à certaines ressources ou à certains flux réseau. Elles peuvent s'appliquer à un routeur, un pare-feu, un commutateur de niveau 3 ou même à un système de fichiers.

Les ACL sont un outil puissant mais sensible : une règle trop permissive ou mal ordonnée peut annuler toute une architecture de sécurité.

DDoS (Distributed Denial of Service):

Une attaque DDoS vise à rendre un service indisponible en l'inondant de requêtes provenant de nombreuses machines compromises. Elle peut saturer la bande passante, épuiser les ressources d'un serveur ou bloquer une application spécifique.

La défense repose sur la détection précoce, le filtrage, le découpage de charge (load balancing), le recours à des CDN ou à des solutions anti-DDoS spécialisées.

PSSI (Politique de Sécurité des Systèmes d'Information):

La PSSI définit les objectifs, les règles et les responsabilités en matière de sécurité au sein d'une organisation. Elle fixe le cadre global : gestion des risques, accès, sauvegardes, sensibilisation, conformité réglementaire et réponse aux incidents.

C'est le document de référence à partir duquel toutes les mesures concrètes de sécurité doivent être alignées.

SOC (Security Operation Center):

Le SOC est l'équipe (ou le service) chargée de surveiller le système d'information en continu. Il collecte et analyse les journaux, détecte les activités suspectes, déclenche les procédures de réponse aux incidents et mène des investigations.

Un SOC mature combine outils avancés (SIEM, EDR, XDR), expertise humaine et veille permanente sur les menaces.

IDS / IPS:

Un IDS détecte les intrusions en analysant le trafic ou les actions exécutées sur un système ; il alerte mais n'agit pas. Un IPS va plus loin : il bloque ou modifie le trafic dangereux dès qu'il est détecté.

En pratique, IDS et IPS sont souvent complémentaires : l'un observe, l'autre protège.

Filtrage:

Le filtrage consiste à contrôler ce qui a le droit de passer : flux réseau, applications, adresses IP, URLs, protocoles ou encore utilisateurs. Il s'effectue au niveau des pare-feux, des proxies, des switches ou des outils applicatifs (WAF, par exemple).

C'est le principe fondamental de réduction de la surface d'attaque.

Vecteur d'attaque:

Un vecteur d'attaque est la voie utilisée par un pirate pour entrer ou exploiter un système. Il peut s'agir d'un email de phishing, d'une faille logicielle, d'un service exposé sans protection, d'identifiants volés ou encore d'une manipulation humaine (ingénierie sociale).

Comprendre les vecteurs d'attaque permet d'anticiper et de réduire les scénarios d'intrusion les plus probables.

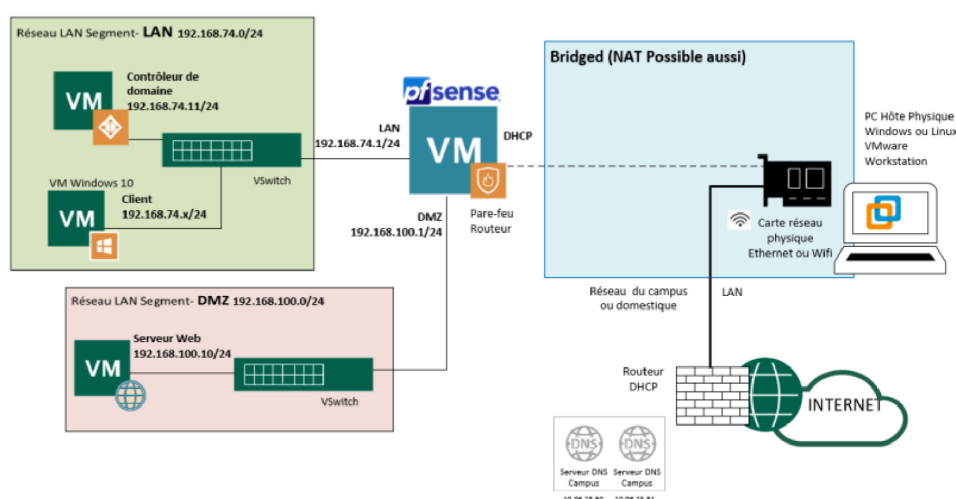
CORBEILLE: SÉCURITÉ ET FILTRAGE

Cette corbeille d'exercices est la suite du workshop « Sécurité/Filtrage » et aborde les points suivants :

- Administration déléguée du pare-feu à l'aide de l'authentification sur Active Directory.
- Mise en place d'un proxy transparent avec Squid.
- Mise en place d'un filtre web avec Squidguard.

CONFIGURATION NÉCESSAIRE

Le plan d'adressage proposé peut être adapté à votre propre Plan s'adressage. Vous devez être capable de vous adapter.



Pour rappel, la topologie déjà configurée lors du workshop «Sécurité/Filtrage» est constituée de 4 machines virtuelles. Dans le cadre de cette corbeille vous n'avez pas besoin du serveur web en DMZ. Vous pouvez l'éteindre pour avoir plus de ressources.

Vous pouvez faire toute la corbeille en utilisant uniquement le serveur Windows 2022 et donc éteindre le PC virtuel W10 ou 11. C'est à votre convenance.

Nécessaire

- Une machine sous pfSense (Firewall) avec 3 interfaces réseau fonctionnelle

Sur le LAN :

- Une machine sous WS 2022 rôle domain controller et serveur DNS

Optionnel

- Une machine sous Windows 10 ou 11 (rôle membre du domaine)

PARTIE 1 - ADMINISTRATION DÉLÉGUÉE DU PARE-FEU

pfSense permet une connexion à un annuaire **LDAP**, notamment Active Directory, pour déléguer l'administration du pare-feu à certains utilisateurs. Vous allez voir dans cette partie comment l'implémenter tout en attribuant et/ou limitant certains accès en fonction des groupes AD correspondants.

- Vous aller créer dans votre domaine Active Directory créé lors d'un Workshop précédent, une Unité d'Organisation qui contiendra des comptes utilisateurs administrateurs du pare-feu avec différents rôles
- Vous allez ensuite paramétrer pfSense pour utiliser ces comptes à l'aide de leur DN.

Vous n'avez pas besoin de votre VM PC W10 ou 11 pour travailler sur cette partie

Création de comptes administrateurs pfsense dans Active Directory

- Connectez-vous sur votre serveur Windows 2022 contrôleur de domaine.
- Vous aller créer une OU dans votre domaine AD, que vous allez nommer 'IT'.
- Vous pouvez utiliser le Centre d'administration Active Directory ou Utilisateurs et ordinateurs Active Directory
- Vous allez créer deux utilisateurs : « admin_junior » et « admin_senior » et un simple utilisateur « pfsense.connect »
- Vous pouvez le faire via deux méthodes : Interface GUI (graphique) et Commandes Powershell.

Question : **Créer les utilisateurs admin_junior et pfsense.connect avec l'interface graphique**

A l'intérieur de l'OU « IT » créée, vous cliquez sur « Create a New User in the current container », et vous entrez les informations relatives à l'utilisateur.

Très important : N'oubliez pas le mot de passe donné à « admin_junior »

Question : **Créer l'utilisateur admin_senior en utilisant powershell**

```
$password="" | ConvertTo-SecureString -AsPlainText -Force  
New-ADUser -Name "admin_senior" -GivenName "Admin" -Surname  
"Senior" -SamAccountName "admin_senior" -UserPrincipalName "
```

Question : **Utilisez La méthode GUI pour créer le groupe « GG_Junior » dans l'OU « IT ».**

A l'intérieur de l'OU « IT » créée, vous cliquez sur « Create a New Group in the current container », et vous entrez les informations relatives au groupe.

Question : **Ajouter l'utilisateur « admin_senior » au groupe « GG_Senior » en utilisant powershell**

```
Add-ADGroupMember -Identity "GG_Senior" -Members "admin_senior"
```

Récupération du Distinguished Name (DN) de l'OU, des Utilisateurs et des Groupes créés

Le **Distinguished Name (DN)** est un identifiant unique utilisé principalement dans les certificats numériques (X.509) et dans **les annuaires LDAP / Active Directory** pour désigner de manière précise une entité (utilisateur, serveur, organisation. . .).

C'est un peu l'équivalent d'un chemin absolu dans un système de fichiers.

Il faut pouvoir identifier de façon claire, unique et hiérarchique chaque objet dans une structure d'annuaire

Abréviation	Nom complet	Rôle dans le DN	Exemple
CN	Common Name	Nom de l'objet (utilisateur, groupe, ordinateur, etc.)	CN=Alan Turing
OU	Organizational Unit	Unité d'organisation (contenant logique d'objets dans l'annuaire)	OU=Comptabilité
DC	Domain Component	Élément du nom de domaine utilisé pour construire le DN	DC=entreprise, DC=local

- L'ordre est **inversé** par rapport à la hiérarchie logique (du plus spécifique au plus général).
- Les DN sont **uniques** dans l'annuaire
- Tous les objets AD (y compris les groupes, ordinateurs, imprimantes) ont un **DN**.
- Le DN complet sert dans les scripts PowerShell, les requêtes LDAP, les outils d'administration.

Question : **Savez-vous retrouver le DN des éléments créés en utilisant POWER-SHELL ?**

- OU : IT
- Utilisateurs : admin_senior et admin_junior
- Groupes : GG_Senior et GG_Junior

```
PS C:\Users\Administrateur> Get-ADUser -Identity "admin_senior"  
| Select-Object DistinguishedName
```

DistinguishedName

CN=admin_senior,OU=IT,DC=lab,DC=intra

```
PS C:\Users\Administrateur> Get-ADGroup -Identity "GG_Senior"  
| Select-Object DistinguishedName
```

DistinguishedName

CN=GG_Senior,OU=IT,DC=lab,DC=intra

```
PS C:\Users\Administrateur> Get-ADOrganizationalUnit -Filter  
"Name -eq 'IT'" | Select-Object DistinguishedName
```

DistinguishedName

OU=IT,DC=lab,DC=intra

Question : **Savez-vous retrouver le DN des éléments créés via l'INTERFACE GRAPHIQUE ?**

Vous devez utiliser les fonctionnalités avancées de la console Utilisateurs et ordinateurs Active Directory

- Ouvrir **Utilisateurs et ordinateurs Active Directory (ADUC)**.
- Activer l'option : **Affichage > Fonctionnalités avancées**.
- Cliquer droit sur un utilisateur > **Propriétés**.
- Onglet **Éditeur d'attributs** (ou "Attribute Editor").
- Chercher **distinguishedName**

[... La suite de la corbeille est disponible dans le fichier séparé corbeille_securite_filtringe.tex ...]

ANALYSE ET RÉOLUTION: SÉCURITÉ ET FILTRAGE

ANALYSER L'ARCHITECTURE EXISTANTE DE BERRIA ET SITUER LA DMZ

L'architecture réseau de BERRIA suit un modèle de sécurité en couches avec trois zones distinctes :

Zone Internet (non maîtrisée) :

Cette zone représente l'extérieur, source de menaces potentielles. Tout trafic en provenance de cette zone est considéré comme non fiable et doit être filtré et inspecté.

DMZ (Zone Démilitarisée) :

Positionnée entre Internet et le réseau interne, la DMZ héberge les services accessibles au public :

- Site portail de l'ERP (interface web publique)
- Serveur de messagerie (SMTP, IMAP)
- Serveurs DNS publics
- Éventuellement : serveur VPN, serveurs web institutionnels

Cette zone est protégée par le pare-feu principal côté Internet, mais reste isolée du réseau interne par un second niveau de filtrage. En cas de compromission d'un serveur dans la DMZ, l'attaquant ne dispose pas d'un accès direct au cœur du système d'information.

Réseau interne (LAN) :

C'est le cœur du SI de BERRIA, hébergeant :

- Les postes de travail des employés
- Les serveurs métiers (ERP, bases de données, applications internes)
- Les ressources de stockage et de sauvegarde
- L'Active Directory et les services d'authentification

Le pare-feu contrôle strictement les flux entre le LAN et la DMZ. Seuls les flux légitimes et nécessaires sont autorisés (par exemple : connexion du serveur web DMZ vers la base de données interne sur des ports spécifiques).

Flux de sécurité :

Le nouveau déploiement inclut :

- Un pare-feu avec IDPS pour détecter et bloquer les intrusions en temps réel
- Un proxy pour filtrer et contrôler les accès web sortants depuis le LAN
- Un UTM (Unified Threat Management) intégrant IDS/IPS, antivirus et filtrage
- Une supervision centralisée vers le SOC pour l'analyse des événements

Cette architecture permet d'appliquer le principe de défense en profondeur : plusieurs couches de sécurité successives limitent la propagation d'une attaque et multiplient les chances de détection.

FAIRE L'INVENTAIRE DES ACL

L'inventaire des ACL existantes chez BERRIA permet d'identifier les points de contrôle actuels et de comprendre comment les flux sont régulés dans l'architecture réseau. Cet inventaire se structure par équipement et par zone.

1. ACL sur le routeur principal (Internet ↔ Pare-feu) :

- **ACL-INTERNET-IN** : Filtre le trafic entrant depuis Internet
 - Bloque les adresses IP privées (RFC 1918) en provenance d'Internet
 - Bloque les paquets avec source spoofée
 - Autorise uniquement les connexions établies (stateful)
 - Limite les flux ICMP (anti-scan, anti-reconnaissance)
- **ACL-INTERNET-OUT** : Contrôle le trafic sortant vers Internet
 - Autorise les flux sortants légitimes depuis la DMZ et le LAN
 - Bloque les protocoles non autorisés (Telnet, FTP non sécurisé)
 - Limite la bande passante par type de flux

2. ACL sur le pare-feu principal (Internet ↔ DMZ) :

- **ACL-DMZ-IN** : Autorise l'accès public aux services exposés
 - HTTP/HTTPS (80, 443) vers serveur web portail ERP
 - SMTP (25, 587) vers serveur de messagerie
 - DNS (53 UDP/TCP) vers serveurs DNS publics
 - VPN (500, 4500 UDP pour IPsec) si applicable
 - Tous les autres flux sont refusés par défaut (deny all)

- **ACL-DMZ-OUT** : Contrôle les flux sortants depuis la DMZ
 - Autorise les réponses aux connexions établies
 - Autorise les mises à jour système (HTTPS vers dépôts officiels)
 - Autorise DNS sortant pour résolution de noms
 - Autorise SMTP sortant pour envoi de mails
 - Bloque toute tentative de connexion vers le LAN interne

3. ACL sur le pare-feu interne (DMZ ↔ LAN) :

- **ACL-LAN-TO-DMZ** : Autorise le LAN à administrer et utiliser la DMZ
 - SSH (22) depuis postes d'administration uniquement
 - RDP (3389) pour administration Windows
 - HTTPS (443) vers portail ERP pour utilisateurs internes
 - Accès base de données (1433 SQL Server, 3306 MySQL, 5432 PostgreSQL) depuis serveurs métiers uniquement
 - Monitoring (SNMP 161/162, Syslog 514) depuis serveur de supervision
- **ACL-DMZ-TO-LAN** : Restreint fortement les accès DMZ vers LAN
 - Accès base de données interne depuis serveur web DMZ (ports spécifiques, IP source précise)
 - Authentification LDAP/AD (389, 636, 88 Kerberos) pour les services DMZ
 - Accès NTP (123) pour synchronisation horaire
 - Tous les autres flux sont bloqués (principe du moindre privilège)

4. ACL sur le pare-feu LAN (Utilisateurs ↔ Internet) :

- **ACL-LAN-OUT** : Régule les accès Internet depuis le LAN
 - HTTP/HTTPS (80, 443) via proxy obligatoire
 - DNS (53) vers serveurs DNS internes uniquement
 - SMTP (587) via serveur mail interne
 - Bloque les accès directs à Internet sans passer par le proxy
 - Bloque les protocoles à risque (P2P, Tor, proxies anonymes)

- **ACL-LAN-INTERNAL** : Segmente le trafic interne
 - VLAN utilisateurs : accès aux serveurs métiers, imprimantes, partages
 - VLAN serveurs : communication inter-serveurs restreinte
 - VLAN administration : accès complet pour équipe IT
 - VLAN IoT/imprimantes : isolé du reste du réseau

5. ACL sur les switches de distribution (segmentation VLAN) :

- **ACL-VLAN** : Contrôle les flux inter-VLAN
 - VLAN 10 (utilisateurs) → VLAN 20 (serveurs) : autorisé avec filtrage
 - VLAN 30 (invités) : isolé, accès Internet uniquement via proxy
 - VLAN 40 (management) : accès SSH/HTTPS aux équipements réseau
 - VLAN 50 (VoIP) : priorisé (QoS) et isolé des autres VLANs

6. ACL proxy (filtrage applicatif web) :

- **ACL-PROXY-WEB** : Contrôle l'accès aux sites web
 - Liste blanche : sites métiers autorisés
 - Liste noire : réseaux sociaux, streaming, sites malveillants
 - Filtrage par catégorie (adultes, jeux, malwares, phishing)
 - Inspection SSL/TLS pour détecter les menaces dans le trafic chiffré
 - Journalisation complète pour audit et conformité

7. ACL pour le projet Cloud/Sauvegarde (à créer) :

Ces ACL devront être ajoutées pour le projet de Léo :

- Flux vers solution de sauvegarde Cloud (ports HTTPS 443, protocoles spécifiques)
- Authentification et chiffrement des données en transit
- Restriction des serveurs autorisés à sauvegarder vers le Cloud
- Monitoring et alertes sur les volumes de données transférées

Constats de l'inventaire :

L'inventaire révèle une architecture de sécurité globalement bien structurée, mais certains points nécessitent attention :

- Les ACL entre DMZ et LAN sont critiques et doivent être auditées régulièrement
- Le projet Cloud/Sauvegarde nécessite de nouvelles règles spécifiques
- Le proxy doit être configuré pour gérer les flux vers les services Cloud
- La documentation des ACL doit être maintenue à jour dans la PSSI

DÉTERMINER LES ACL NÉCESSAIRE

Pour le projet de sauvegarde et de sécurisation des données vers le Cloud, Léo doit déterminer les ACL spécifiques qui permettront de sécuriser les flux tout en respectant la PSSI de BERRIA. Cette analyse se base sur les besoins fonctionnels du projet et les contraintes de sécurité.

1. ACL-CLOUD-BACKUP-OUT : Flux sortants vers la solution Cloud :

Cette ACL contrôle les connexions depuis le réseau interne vers les services de sauvegarde Cloud.

- **Source** : Serveurs de sauvegarde autorisés (liste IP précise)
 - Serveur principal de backup : 10.10.20.10
 - Serveur secondaire de backup : 10.10.20.11
 - Pas d'autorisation pour d'autres serveurs ou postes utilisateurs
- **Destination** : Adresses IP du fournisseur Cloud (plages spécifiques)
 - Plage IP du datacenter Cloud principal (exemple : 52.x.x.x/24)
 - Plage IP du datacenter Cloud secondaire (redondance géographique)
 - FQDN autorisés : backup.cloudprovider.com, storage.cloudprovider.com
- **Protocoles et ports autorisés** :
 - HTTPS (TCP 443) : transfert de données chiffrées
 - TLS 1.2 minimum, TLS 1.3 recommandé
 - API REST du fournisseur Cloud (port spécifique si différent)
 - S3-compatible (TCP 443) si utilisation de protocole S3
- **Restrictions temporelles** :
 - Fenêtre de sauvegarde : 22h00 - 06h00 (heures creuses)
 - Possibilité de sauvegardes incrémentielles en journée si nécessaire
 - Alertes si tentative de connexion hors fenêtre autorisée
- **Limitations de débit** :
 - Bande passante maximale : 100 Mbps (éviter la saturation)
 - QoS : priorité basse en journée, priorité normale la nuit

2. ACL-CLOUD-MGMT : Gestion et administration Cloud :

Cette ACL autorise les administrateurs à gérer la solution de sauvegarde Cloud.

- **Source** : Postes d'administration IT uniquement
 - Postes admin VLAN 40 (management) : 10.10.40.0/24
 - VPN administrateur pour accès distant sécurisé
- **Destination** : Portails d'administration Cloud
 - Console web fournisseur : admin.cloudprovider.com
 - API management : api.cloudprovider.com
- **Protocoles autorisés** :
 - HTTPS (TCP 443) : accès portail web
 - SSH (TCP 22) : si accès serveur de gestion nécessaire
 - RDP (TCP 3389) : si machine virtuelle de gestion dans le Cloud
- **Authentification renforcée** :
 - MFA (Multi-Factor Authentication) obligatoire
 - Intégration avec Active Directory BERRIA (SAML, LDAPS)
 - Journalisation complète des accès administrateur

3. ACL-CLOUD-RESTORE : Flux de restauration depuis le Cloud :

Cette ACL gère les restaurations de données depuis le Cloud vers l'infrastructure BERRIA.

- **Source** : Serveurs Cloud du fournisseur
 - Connexions entrantes initiées par demande de restauration
 - Validation via token de session sécurisé
- **Destination** : Serveurs de backup ou serveurs cibles
 - Serveurs backup : 10.10.20.10, 10.10.20.11
 - Serveurs métiers spécifiques en cas de restauration directe (après validation)
- **Protocoles autorisés** :
 - HTTPS (TCP 443) : téléchargement des données chiffrées
 - Vérification d'intégrité (checksums, signatures)
- **Règle particulière** :
 - Activation manuelle de l'ACL lors d'une restauration (désactivée par défaut)
 - Durée limitée : 24-48h maximum
 - Supervision renforcée pendant la restauration

4. ACL-CLOUD-PROXY : Routage via proxy pour inspection :

Le proxy doit être intégré dans le flux Cloud pour assurer le contrôle et la visibilité.

- **Configuration proxy :**
 - Tous les flux Cloud passent obligatoirement par le proxy
 - Proxy : 10.10.30.5 (port 8080 ou 3128)
 - Exceptions : aucune (pas de bypass autorisé)
- **Inspection SSL/TLS :**
 - Déchiffrement SSL pour inspection (avec certificat interne BERRIA)
 - Vérification des signatures et certificats Cloud
 - Détection de malwares dans les flux chiffrés
- **Journalisation proxy :**
 - Logs détaillés : source, destination, volume, durée
 - Envoi des logs au SIEM pour corrélation
 - Alertes sur anomalies (volumes inhabituels, destinations suspectes)

5. ACL-CLOUD-DMZ : Accès depuis/vers la DMZ :

Si des services DMZ doivent sauvegarder vers le Cloud.

- **Serveurs DMZ autorisés :**
 - Serveur web portail ERP (base de données statique)
 - Serveur de messagerie (archives emails)
- **Flux strictement contrôlés :**
 - Connexions sortantes uniquement (jamais d'entrées non sollicitées)
 - HTTPS (TCP 443) vers Cloud uniquement
 - Passage obligatoire via proxy DMZ dédié
- **Isolation renforcée :**
 - Aucun flux direct DMZ → LAN pour le backup
 - Les restaurations DMZ passent par un serveur intermédiaire validé

6. ACL-CLOUD-MONITORING : Supervision et alertes :

Surveillance des flux Cloud pour détecter les anomalies.

- **Serveur de monitoring** : 10.10.20.100
 - Collecte des métriques via SNMP, API, Syslog
 - Accès lecture seule aux logs pare-feu, proxy, serveurs backup
- **Règles de détection** :
 - Volume de données excessif (exfiltration potentielle)
 - Connexions vers IPs Cloud non autorisées
 - Échecs d'authentification répétés
 - Tentatives de connexion hors fenêtre de backup
- **Intégration SOC** :
 - Envoi automatique des alertes vers le SOC BERRIA
 - Corrélation avec l'IDPS et le SIEM
 - Procédures de réponse aux incidents définie dans la PSSI

7. ACL-CLOUD-DENY : Règles de blocage explicites :

Ces règles bloquent les comportements non autorisés.

- **Blocages absolus** :
 - Tout trafic Cloud depuis postes utilisateurs (VLAN 10)
 - Protocoles non chiffrés (HTTP, FTP, Telnet) vers le Cloud
 - Connexions vers services Cloud non approuvés (Google Drive personnel, Dropbox, etc.)
 - Transferts de fichiers exécutables (.exe, .bat, .sh) vers le Cloud sans validation
- **Protection contre l'exfiltration** :
 - DLP (Data Loss Prevention) sur le proxy
 - Blocage de fichiers sensibles détectés (mots-clés, patterns)
 - Alerte immédiate en cas de tentative de contournement

Synthèse des ACL nécessaires au projet Cloud/Sauvegarde :

- **7 catégories d'ACL** couvrant tous les flux (backup, gestion, restauration, proxy, DMZ, monitoring, blocage)
- **Principe du moindre privilège** : seuls les serveurs autorisés peuvent accéder au Cloud
- **Chiffrement obligatoire** : TLS 1.2 minimum sur tous les flux
- **Passage obligatoire par le proxy** : inspection et journalisation complètes
- **Supervision continue** : intégration SOC, SIEM, IDPS
- **Conformité PSSI** : toutes les règles documentées et approuvées

Ces ACL permettent à Léo de sécuriser son projet tout en maintenant la visibilité et le contrôle nécessaires à la conformité de BERRIA.

LISTER LES FLUX RÉSEAUX REQUIS

Pour le projet Cloud/Sauvegarde de BERRIA, Léo doit identifier précisément tous les flux réseau nécessaires, en spécifiant les protocoles, ports TCP/UDP, sources et destinations. Cette liste servira de base à la configuration du pare-feu et du proxy.

1. Flux de sauvegarde vers le Cloud (LAN → Internet) :

Source	Destination	Protocole	Port	Usage
10.10.20.10	backup.cloud.com	TCP	443	Transfert HTTPS chiffré
10.10.20.11	backup.cloud.com	TCP	443	Transfert HTTPS chiffré
10.10.20.10	storage.cloud.com	TCP	443	API REST/S3
10.10.20.11	storage.cloud.com	TCP	443	API REST/S3
Serveurs backup	52.x.x.x/24	TCP	443	Datacenter Cloud principal
Serveurs backup	DNS interne	UDP	53	Résolution de noms
Serveurs backup	NTP interne	UDP	123	Synchronisation horaire

2. Flux d'administration Cloud (VLAN Management → Internet) :

Source	Destination	Protocole	Port	Usage
10.10.40.0/24	admin.cloud.com	TCP	443	Console web
10.10.40.0/24	api.cloud.com	TCP	443	API management
Postes admin	Portail Cloud	TCP	443	Gestion backups

3. Flux de restauration (Internet → LAN) :

Source	Destination	Protocole	Port	Usage
52.x.x.x/24	10.10.20.10	TCP	443	Téléchargement données
Cloud provider	Serveurs backup	TCP	443	Restauration chiffrée

Note : Ces flux ne sont actifs que lors d'une restauration validée, avec activation manuelle temporaire.

4. Flux via proxy (LAN → Proxy → Internet) :

Source	Destination	Protocole	Port	Usage
Serveurs backup	10.10.30.5	TCP	8080	Proxy sortant
10.10.40.0/24	10.10.30.5	TCP	8080	Proxy admin
10.10.30.5	Internet Cloud	TCP	443	Sortie proxy
Proxy	LDAP/AD	TCP	389/636	Authentification

5. Flux de monitoring et supervision (Tous → Monitoring) :

Source	Destination	Protocole	Port	Usage
Serveurs backup	10.10.20.100	UDP	514	Syslog
Pare-feu	10.10.20.100	UDP	514	Logs firewall
Proxy	10.10.20.100	TCP	514	Logs proxy
Équipements réseau	10.10.20.100	UDP	161	SNMP
10.10.20.100	SIEM/SOC	TCP	6514	Logs chiffrés

6. Flux DMZ vers Cloud (DMZ → Internet) :

Source	Destination	Protocole	Port	Usage
Serveur web DMZ	backup.cloud.com	TCP	443	Backup site web
Serveur mail DMZ	backup.cloud.com	TCP	443	Archives emails
DMZ	Proxy DMZ	TCP	8080	Routage obligatoire

7. Flux d'authentification (Serveurs → Active Directory) :

Source	Destination	Protocole	Port	Usage
Serveurs backup	AD (10.10.20.5)	TCP	389	LDAP
Serveurs backup	AD (10.10.20.5)	TCP	636	LDAPS (chiffré)
Proxy	AD (10.10.20.5)	TCP	88	Kerberos
Services Cloud	AD (10.10.20.5)	TCP	636	Auth LDAPS

8. Flux IDPS et UTM (Surveillance) :

Source	Destination	Protocole	Port	Usage
IDPS	Tous les flux	Miroir	-	Inspection passive
IDPS	10.10.20.100	TCP	514	Alertes Syslog
UTM	Tous les flux	Inline	-	Inspection active
UTM	Internet	TCP	443	MAJ signatures

Synthèse des besoins réseau :

- **Protocole principal** : HTTPS/TLS (TCP 443) pour tous les flux Cloud
- **Protocoles auxiliaires** : DNS (53), NTP (123), LDAP/S (389/636), Syslog (514), SNMP (161)
- **Bande passante estimée** : 50-100 Mbps en heures creuses, 10-20 Mbps en journée
- **Fenêtre principale** : 22h00-06h00 (sauvegardes complètes), 24h/24 (incrémentielles)
- **Sources autorisées** : Serveurs backup (2), postes admin (VLAN 40), serveurs DMZ (2)
- **Destinations** : Plages IP Cloud fournisseur, FQDN validés uniquement

DÉFINIR LES RÈGLES DE FILTRAGE (ACL) NÉCESSAIRES SUR LE PARE-FEU.

À partir de l'inventaire des ACL et de la liste des flux requis, Léo doit maintenant définir les règles de filtrage précises à implémenter sur le pare-feu. Ces règles suivent le principe du moindre privilège et le modèle deny-all par défaut.

Configuration du pare-feu : Règles sortantes LAN → Internet (Cloud)

```
# Règle 1 : Backup serveur principal vers Cloud
acl 100 permit tcp host 10.10.20.10
52.0.0.0 0.255.255.255 eq 443
acl 100 permit tcp host 10.10.20.10 host
backup.cloudprovider.com eq 443

# Règle 2 : Backup serveur secondaire vers Cloud
acl 101 permit tcp host 10.10.20.11
52.0.0.0 0.255.255.255 eq 443
acl 101 permit tcp host 10.10.20.11 host
storage.cloudprovider.com eq 443

# Règle 3 : Administration Cloud depuis VLAN Management
acl 102 permit tcp 10.10.40.0 0.0.0.255 host
admin.cloudprovider.com eq 443
acl 102 permit tcp 10.10.40.0 0.0.0.255 host
api.cloudprovider.com eq 443

# Règle 4 : DNS pour résolution Cloud
(serveurs backup uniquement)
acl 103 permit udp host 10.10.20.10 host
10.10.1.1 eq 53
acl 103 permit udp host 10.10.20.11 host
10.10.1.1 eq 53

# Règle 5 : NTP pour synchronisation horaire
acl 104 permit udp host 10.10.20.10 host
10.10.1.2 eq 123
acl 104 permit udp host 10.10.20.11 host
10.10.1.2 eq 123

# Règle 6 : Tous les flux Cloud doivent
passer par le proxy
acl 105 deny tcp any any eq 443 log
acl 105 remark "Blocage bypass proxy"
```

Configuration du pare-feu : Règles entrantes Internet → LAN (Restauration)

```
# Règle 10 : Restauration Cloud (DÉSACTIVÉE par défaut)
acl 200 remark "Activation manuelle uniquement lors restauration"
acl 200 deny tcp 52.0.0.0 0.255.255.255 host 10.10.20.10 eq 443
acl 200 deny tcp 52.0.0.0 0.255.255.255 host 10.10.20.11 eq 443

# Pour activer temporairement (commande admin) :
# acl 200 permit tcp 52.0.0.0 0.255.255.255 host 10.10.20.10 eq 443
# acl 200 time-range RESTORE-WINDOW (24-48h max)
```

Configuration du pare-feu : Règles DMZ → Internet (Cloud)

```
# Règle 20 : Serveur web DMZ vers Cloud backup
acl 300 permit tcp host 192.168.100.10 host
backup.cloudprovider.com eq 443
acl 300 remark "Backup portail ERP"

# Règle 21 : Serveur mail DMZ vers Cloud backup
acl 301 permit tcp host 192.168.100.20 host
backup.cloudprovider.com eq 443
acl 301 remark "Archives emails"

# Règle 22 : Bloquer tout autre flux DMZ vers Cloud
acl 302 deny ip 192.168.100.0 0.0.0.255 any log
acl 302 remark "Deny all autres flux DMZ"
```

Configuration du pare-feu : Règles de monitoring

```
# Règle 30 : Syslog vers serveur monitoring
acl 400 permit udp host 10.10.20.10 host 10.10.20.100 eq 514
acl 400 permit udp host 10.10.20.11 host 10.10.20.100 eq 514
acl 400 permit udp host 10.10.30.5 host 10.10.20.100 eq 514

# Règle 31 : SNMP depuis monitoring vers équipements
acl 401 permit udp host 10.10.20.100 10.10.0.0 0.0.255.255 eq 161

# Règle 32 : Logs vers SIEM/SOC
acl 402 permit tcp host 10.10.20.100 host 10.10.20.200 eq 6514
```

Configuration du pare-feu : Règles d'authentification AD/LDAP

```
# Règle 40 : LDAPS pour authentification sécurisée
acl 500 permit tcp host 10.10.20.10 host 10.10.20.5 eq 636
acl 500 permit tcp host 10.10.20.11 host 10.10.20.5 eq 636
acl 500 permit tcp host 10.10.30.5 host 10.10.20.5 eq 636

# Règle 41 : Kerberos pour proxy
acl 501 permit tcp host 10.10.30.5 host 10.10.20.5 eq 88
acl 501 permit udp host 10.10.30.5 host 10.10.20.5 eq 88
```

Configuration du pare-feu : Règles de blocage (Sécurité renforcée)

```
# Règle 50 : Bloquer postes utilisateurs vers Cloud
acl 600 deny tcp 10.10.10.0 0.0.0.255 52.0.0.0 0.255.255.255 eq 443 log
acl 600 remark "Utilisateurs ne peuvent pas accéder au Cloud directement"

# Règle 51 : Bloquer protocoles non chiffrés vers Cloud
acl 601 deny tcp any any eq 80 log
acl 601 deny tcp any any eq 21 log
acl 601 deny tcp any any eq 23 log
acl 601 remark "Protocoles non sécurisés interdits"

# Règle 52 : Bloquer services Cloud non approuvés
acl 602 deny tcp any host drive.google.com eq 443 log
acl 602 deny tcp any host dropbox.com eq 443 log
acl 602 deny tcp any host onedrive.live.com eq 443 log
acl 602 remark "Shadow IT interdit"

# Règle 53 : Limitation de bande passante (QoS)
acl 603 remark "Rate-limit 100Mbps pour flux Cloud"
class-map CLOUD-TRAFFIC
  match access-group 100
  match access-group 101
policy-map QOS-CLOUD
  class CLOUD-TRAFFIC
    police 100000000 conform transmit exceed drop
```

Configuration du pare-feu : Règles temporelles (Time-based ACL)

```
# Règle 60 : Fenêtre de sauvegarde (22h-6h)
time-range BACKUP-WINDOW
  periodic daily 22:00 to 23:59
  periodic daily 00:00 to 06:00

acl 700 permit tcp host 10.10.20.10 52.0.0.0 0.255.255.255 eq 443
  time-range BACKUP-WINDOW
acl 700 remark "Sauvegardes complètes en heures creuses"

# Règle 61 : Sauvegardes incrémentielles 24h/24 (priorité basse)
time-range BUSINESS-HOURS
  periodic weekdays 08:00 to 18:00

acl 701 permit tcp host 10.10.20.10 52.0.0.0 0.255.255.255 eq 443
  time-range BUSINESS-HOURS precedence routine
acl 701 remark "Incrémentielles en journée (QoS basse)"
```

Configuration du pare-feu : Règle par défaut (Deny All)

```
# Règle 999 : Deny all implicite  
acl 999 deny ip any any log  
acl 999 remark "Tout ce qui n'est pas explicitement autorisé est interdit"
```

Ordre d'application des règles :

1. Règles de blocage explicites (600-602) : bloquer les comportements interdits
2. Règles d'autorisation spécifiques (100-105, 200, 300-302) : flux Cloud légitimes
3. Règles de services (400-402, 500-501) : monitoring, authentification
4. Règles temporelles (700-701) : gestion des fenêtres de sauvegarde
5. Règle par défaut (999) : deny all implicite

Logging et alertes :

- Tous les deny sont loggés pour analyse SOC
- Les permit sensibles (restauration, admin) sont loggés
- Alertes automatiques : tentatives de bypass proxy, volumes anormaux, échecs répétés
- Conservation des logs : 90 jours minimum (conformité RGPD/PSSI)

Maintenance et révision :

- Audit trimestriel des règles ACL
- Suppression des règles obsolètes
- Documentation à jour dans la PSSI
- Tests de pénétration annuels pour validation

CONFIGURER LE RÔLE DU PROXY DANS L'INFRASTRUCTURE.

Le proxy est un élément central de la stratégie de sécurité de BERRIA pour le projet Cloud. Contrairement à ce que pensait initialement Léo (contourner les restrictions géographiques de streaming), le proxy d'entreprise a des fonctions de sécurité, de contrôle et de visibilité essentielles.

Rôles du proxy dans l'infrastructure BERRIA :

1. Filtrage et contrôle d'accès web

- **Filtrage par URL** : Bloquer l'accès aux services Cloud non autorisés (Dropbox, Google Drive personnel, WeTransfer)
- **Filtrage par catégorie** : Réseaux sociaux, streaming, jeux, contenus malveillants, phishing
- **Liste blanche** : Seuls les domaines Cloud approuvés (backup.cloudprovider.com) sont autorisés
- **Liste noire dynamique** : Mise à jour via flux de threat intelligence
- **Analyse de réputation** : Vérification des domaines via bases de données (Virus-Total, AlienVault)

2. Inspection SSL/TLS (Deep Packet Inspection)

- **Déchiffrement SSL** : Le proxy agit comme man-in-the-middle légitime
- **Certificat interne BERRIA** : Déployé sur tous les postes via GPO Active Directory
- **Inspection du contenu** : Détection de malwares dans les flux HTTPS chiffrés
- **Validation des certificats** : Vérification que les certificats Cloud sont légitimes
- **Détection d'anomalies** : Identification de protocoles tunnelisés (VPN dans HTTPS, C2 malware)

3. Prévention de la perte de données (DLP - Data Loss Prevention)

- **Analyse de contenu** : Détection de données sensibles (numéros CB, IBAN, données personnelles)
- **Mots-clés sensibles** : "Confidentiel", "Secret", noms de clients stratégiques
- **Patterns regex** : Détection de formats SIRET, SIREN, numéros de sécurité sociale
- **Blocage uploads suspects** : Interdiction de transférer des fichiers .exe, .bat, .ps1 vers le Cloud
- **Watermarking** : Marquage des documents téléchargés pour traçabilité

4. Authentification et autorisation

- **Intégration Active Directory** : Authentification transparente via Kerberos/NTLM
- **Authentification explicite** : Login/password pour accès web si nécessaire
- **Groupes AD** : Autorisations différenciées selon les groupes (Admins, Utilisateurs, Invités)
- **SSO (Single Sign-On)** : Intégration SAML pour accès portails Cloud
- **MFA sur actions sensibles** : Double authentification pour accès admin Cloud

5. Journalisation et audit

- **Logs détaillés** : User, timestamp, URL, action (allow/deny), volume transféré
- **Conservation** : 90 jours minimum (RGPD), 1 an pour logs sensibles
- **Envoi au SIEM** : Corrélation avec logs pare-feu, IDPS, Active Directory
- **Alertes temps réel** : Tentatives répétées d'accès bloqués, volumes anormaux
- **Rapports mensuels** : Top sites, top users, incidents de sécurité

6. Performance et optimisation

- **Cache web** : Mise en cache des contenus fréquents (mises à jour, pages statiques)
- **Compression** : Réduction de la bande passante (gzip, brotli)
- **Optimisation TCP** : Connection pooling, keep-alive
- **QoS** : Priorisation des flux métiers sur le streaming/social
- **Load balancing** : Répartition sur plusieurs instances proxy si charge élevée

7. Protection contre les attaques

- **Anti-malware** : Scan en temps réel des fichiers téléchargés
- **Anti-phishing** : Détection de sites frauduleux usurpant identité (faux portails Cloud)
- **Protection DDoS** : Rate limiting, détection de flood
- **Blocage exploits** : Filtrage de payloads malveillants dans requêtes HTTP
- **Sandboxing** : Exécution de fichiers suspects dans environnement isolé

Configuration technique du proxy pour le projet Cloud :

```
# Configuration Squid/Proxy BERRIA pour Cloud Backup

# Écoute
http_port 10.10.30.5:8080 ssl-bump
    cert=/etc/proxy/certs/berria-ca.crt
    key=/etc/proxy/certs/berria-ca.key

# Authentification AD
auth_param ntlm program /usr/bin/ntlm_auth
auth_param ntlm children 10
auth_param basic program /usr/bin/ldap_auth -b "dc=berria,dc=local"
acl authenticated proxy_auth REQUIRED

# ACL Cloud autorisé
acl cloud_approved dstdomain .cloudprovider.com backup.cloudprovider.com
acl cloud_servers src 10.10.20.10 10.10.20.11
acl cloud_admins src 10.10.40.0/24

# ACL Cloud interdit (Shadow IT)
acl shadow_it dstdomain .dropbox.com .drive.google.com .onedrive.com
acl shadow_it dstdomain .wetransfer.com .mega.nz .mediafire.com

# Règles d'accès
http_access deny shadow_it
http_access allow cloud_servers cloud_approved
http_access allow cloud_admins cloud_approved authenticated
http_access deny all

# SSL Bump (inspection HTTPS)
sslcrttd_program /usr/lib/squid/ssl_crttd -s /var/lib/ssl_db -M 4MB
acl step1 at_step SslBump1
ssl_bump peek step1
ssl_bump bump all

# DLP - Blocage types de fichiers
acl blocked_files urlpath_regex -i \.exe$ \.bat$ \.ps1$ \.sh$ \.msi$
http_access deny blocked_files

# Logging
access_log /var/log/squid/access.log squid
cache_log /var/log/squid/cache.log
cache_store_log /var/log/squid/store.log

# Envoi logs vers SIEM
logfile_rotate 7
log_fqdn on
strip_query_terms off
```

```
# Performance
cache_mem 2048 MB
maximum_object_size 512 MB
cache_dir ufs /var/spool/squid 10000 16 256

# Rate limiting (protection DDoS)
delay_pools 1
delay_class 1 2
delay_parameters 1 100000/100000 10000/10000
delay_access 1 allow all
```

Intégration du proxy dans l'architecture :

- **Position réseau** : Entre le LAN et le pare-feu sortant, en série (pas de bypass possible)
- **Mode transparent** : Les utilisateurs ne configurent rien (redirection automatique via pare-feu)
- **Haute disponibilité** : 2 proxies en load balancing (actif/actif)
- **Failover** : Bascule automatique si un proxy tombe (keepalived, VRRP)
- **WPAD/PAC** : Configuration automatique via GPO Active Directory

Relation proxy - pare-feu - IDPS :

- **Couche 1 : Pare-feu** : Filtre IP/ports (ACL réseau)
- **Couche 2 : Proxy** : Filtre URLs/contenu (ACL applicative)
- **Couche 3 : IDPS** : Détecte comportements anormaux (signatures, anomalies)
- **Synergie** : Les 3 équipements envoient leurs logs au SIEM pour corrélation
- **Exemple** : IDPS détecte exfiltration → alerte SOC → blocage immédiat sur proxy + pare-feu

Impact du proxy sur le projet de Léo :

- **Visibilité totale** : Tous les flux Cloud sont inspectés et loggés
- **Contrôle granulaire** : Distinction entre backup légitime et exfiltration malveillante
- **Conformité PSSI** : Respect des obligations de traçabilité et d'audit
- **Protection DLP** : Empêche la fuite de données sensibles vers le Cloud
- **Authentification** : Traçabilité nominative des actions (qui a fait quoi)

Léo comprend maintenant que le proxy n'est pas un outil de contournement, mais un pilier de la sécurité du SI. Sans proxy, impossible de garantir la visibilité et le contrôle des flux Cloud exigés par la PSSI de BERRIA.

ÉVALUER LES RISQUES ET L'IMPACT SUR LA DMZ

Le projet de sauvegarde Cloud de Léo impacte directement la DMZ de BERRIA, car certains serveurs exposés (portail ERP, messagerie) doivent également être sauvegardés. Cette analyse évalue les risques et propose des mesures de mitigation.

Risques identifiés

Risque 1 : Compromission d'un serveur DMZ et exfiltration via le Cloud

- **Scénario** : Un attaquant compromise le serveur web DMZ et utilise les identifiants Cloud pour exfiltrer des données
- **Probabilité** : Moyenne (la DMZ est exposée à Internet)
- **Impact** : Critique (vol de données sensibles, atteinte à la réputation)
- **Vecteur** : Exploitation d'une vulnérabilité web (SQL injection, RCE), credential stuffing
- **Mitigation** :
 - Pas de stockage d'identifiants Cloud sur serveurs DMZ
 - Authentification Cloud via certificats (pas de mots de passe)
 - Isolation réseau : serveurs DMZ ne peuvent pas initier de connexions Cloud directes
 - Backup DMZ via serveur relais dans le LAN (pas d'accès direct DMZ → Cloud)
 - IDPS surveille les comportements anormaux (connexions inhabituelles, volumes excessifs)

Risque 2 : Pivot depuis la DMZ vers le LAN via les flux de backup

- **Scénario** : Attaquant dans la DMZ utilise les connexions backup pour rebondir vers le réseau interne
- **Probabilité** : Faible (si architecture bien cloisonnée)
- **Impact** : Critique (accès au cœur du SI)
- **Vecteur** : Exploitation d'une relation de confiance DMZ ↔ LAN, mouvement latéral
- **Mitigation** :
 - Aucun flux direct DMZ → LAN pour le backup (architecture en relais)
 - Serveur de backup LAN initie les connexions vers DMZ (pull, pas push)
 - Authentification forte et segmentation réseau stricte
 - Principe du moindre privilège : serveurs DMZ ont accès minimal au LAN
 - Surveillance renforcée des flux DMZ ↔ LAN par l'IDPS

Risque 3 : DDoS sur les services DMZ impactant les sauvegardes

- **Scénario** : Attaque DDoS sature la bande passante, empêchant les sauvegardes Cloud de se terminer
- **Probabilité** : Moyenne (attaques DDoS fréquentes)
- **Impact** : Modéré (interruption de service, sauvegardes incomplètes)
- **Vecteur** : Botnet, amplification DNS/NTP, flood SYN/UDP
- **Mitigation** :
 - Pare-feu avec protection DDoS (rate limiting, SYN cookies)
 - QoS : priorisation des flux backup sur les flux web publics
 - CDN et reverse proxy pour absorber les attaques DDoS
 - Fenêtre de backup étendue (si interruption, reprise automatique)
 - Alertes automatiques si sauvegardes échouent plusieurs fois

Risque 4 : Restauration malveillante depuis un backup compromis

- **Scénario** : Un attaquant modifie un backup Cloud et déclenche une restauration pour injecter du malware
- **Probabilité** : Très faible (si chiffrement et signature corrects)
- **Impact** : Critique (infection généralisée du SI)
- **Vecteur** : Compromission du compte Cloud admin, injection de ransomware dans backup
- **Mitigation** :
 - Chiffrement bout-en-bout des backups (clés sous contrôle BERRIA, pas du fournisseur Cloud)
 - Signature cryptographique des backups (vérification d'intégrité avant restauration)
 - Immutabilité des backups Cloud (WORM - Write Once Read Many)
 - Restauration dans environnement isolé (sandbox) pour validation avant déploiement
 - MFA obligatoire pour toute restauration
 - Validation manuelle par 2 administrateurs (principe du double contrôle)

Risque 5 : Saturation de la DMZ par le trafic de backup

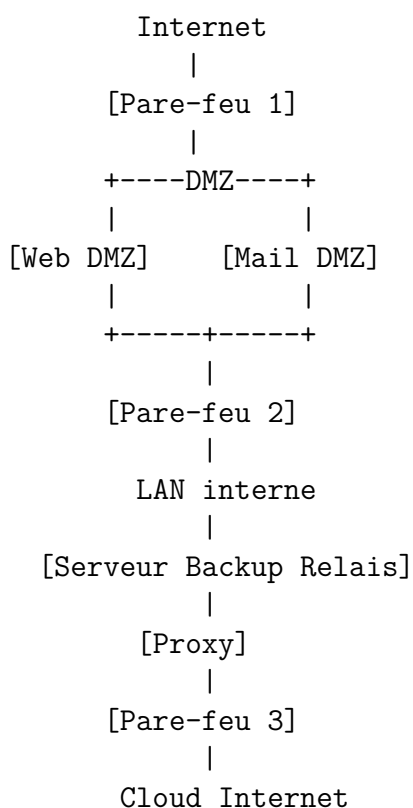
- **Scénario** : Les sauvegardes DMZ consomment toute la bande passante, impactant les services publics
- **Probabilité** : Moyenne (si pas de QoS configuré)
- **Impact** : Modéré (dégradation de performance des services web/mail)
- **Vecteur** : Backup mal planifié, transferts de gros volumes
- **Mitigation** :
 - QoS avec limitation de bande passante pour backups (max 30% de la BP totale)
 - Fenêtre de backup en heures creuses (22h-6h)
 - Sauvegardes différentielles/incrémentielles (pas de full quotidien)
 - Compression et déduplication avant envoi vers Cloud
 - Monitoring en temps réel de la BP et alertes si seuil dépassé

Risque 6 : Exposition d'informations sensibles via logs/metadata

- **Scénario** : Les logs de backup ou metadata révèlent des informations sur l'architecture interne
- **Probabilité** : Faible (si bonne configuration)
- **Impact** : Faible à modéré (reconnaissance pour attaque future)
- **Vecteur** : Logs non chiffrés, metadata lisibles, erreurs exposant chemins internes
- **Mitigation** :
 - Chiffrement des logs avant envoi au Cloud
 - Anonymisation des chemins et noms de serveurs dans les logs
 - Stockage des logs dans zone Cloud privée (pas de buckets publics)
 - Audit régulier des permissions Cloud (principe du moindre privilège)

Impact architectural sur la DMZ

Configuration recommandée : Architecture en relais



Flux de backup DMZ :

1. Serveur backup LAN initie connexion vers serveur DMZ (pull, port 22 SSH ou 3389 RDP)
2. Serveur backup LAN récupère les données depuis DMZ
3. Serveur backup LAN chiffre et compresse les données
4. Serveur backup LAN envoie vers Cloud via proxy (inspection SSL)
5. Aucun flux direct DMZ → Cloud (isolation totale)

Mise à jour de la PSSI

Le projet Cloud/Backup de Léo nécessite une mise à jour de la PSSI de BERRIA :

• Chapitre 3.5 : Sauvegarde et restauration

- Ajout du volet Cloud (fournisseur, SLA, RPO/RTO)
- Procédures de backup DMZ (architecture en relais)
- Tests de restauration trimestriels obligatoires

- **Chapitre 4.2 : Filtrage réseau**
 - Nouvelles ACL Cloud (référence vers les règles définies)
 - Rôle du proxy dans les flux Cloud
 - Procédures de validation des modifications ACL
- **Chapitre 5.1 : Gestion des identités**
 - Authentification Cloud (MFA obligatoire)
 - Gestion des comptes de service
 - Procédure de révocation en cas de compromission
- **Chapitre 6.3 : Réponse aux incidents**
 - Scénarios spécifiques Cloud (exfiltration, compromission backup)
 - Procédures d'escalade vers SOC
 - Contacts fournisseur Cloud en cas d'incident

Plan de déploiement sécurisé

1. **Phase 1 : Préparation (2 semaines)**
 - Configuration pare-feu : implémentation des ACL Cloud
 - Configuration proxy : règles de filtrage, inspection SSL, DLP
 - Tests en environnement de recette (pas de production)
2. **Phase 2 : Déploiement LAN uniquement (2 semaines)**
 - Activation backup serveurs LAN vers Cloud
 - Surveillance renforcée (SOC en alerte)
 - Validation de l'intégrité des backups
3. **Phase 3 : Extension DMZ via relais (2 semaines)**
 - Configuration serveur backup relais
 - Backup serveurs DMZ via relais LAN (pas de flux direct)
 - Tests de restauration DMZ en environnement isolé
4. **Phase 4 : Validation et production (1 semaine)**
 - Test de restauration complète (DR - Disaster Recovery)
 - Validation conformité PSSI
 - Documentation finale et formation équipe IT
 - Mise en production définitive

CONCLUSION

Le projet Cloud/Backup de Léo impacte significativement la DMZ, mais avec une architecture en relais et des mesures de mitigation appropriées, les risques sont maîtrisés. L'intégration du proxy, du pare-feu IDPS et la surveillance SOC garantissent la visibilité et le contrôle des flux. La mise à jour de la PSSI et le plan de déploiement progressif assurent une transition sécurisée vers le Cloud.

Léo peut maintenant finaliser son rapport avec confiance, sachant que son projet respecte les exigences de sécurité de BERRIA et s'intègre harmonieusement dans l'architecture existante.

CAPITALISATION

AAV	Commentaire	Statut
Analyser de manière holistique la sécurité du S.I.	Analyse complète fournie : architecture en couches, inventaire des ACL, évaluation des risques, plan de déploiement et scénarios de mitigation.	Acquis
Expliquer le principe de Zone Démilitarisée (DMZ)	Définition, rôle et positionnement de la DMZ présentés ; architecture en relais et mesures d'isolation proposées.	Acquis
Sélectionner le filtrage réseau adapté	Catalogue détaillé d'ACL et règles (sortantes/entrantes, DMZ, LAN, proxy, time-based, QoS) avec exemples de configuration.	Acquis
Administrer un proxy	Rôles du proxy (filtrage, SSL inspection, DLP, auth AD) et configuration Squid fournie ; haute disponibilité et intégration SIEM abordées.	Acquis
Rappeler le cadre légal	Mention de la PSSI et conformité (logs, conservation, RGPD) mais absence d'un chapitre juridique détaillé ou de procédures de conformité complètes.	Partiel
Préparer et configurer un pare-feu	Jeu de règles complet (ACL, time-range, rate-limit, deny-all), logging et plan de maintenance définis ; exemples de commandes fournis.	Acquis
Relier les outils de sécurité à l'annuaire du S.I.	Intégration LDAP/AD évoquée pour pfSense et proxy (authentification, groupes) ; procédure d'implémentation et tests pratiques incomplets.	Partiel

QUESTIONS DE VALIDATION

1. Que représente une DMZ ?

Zone tampon entre Internet et le réseau interne hébergeant les services publics (web, mail, VPN). Objectifs : cloisonner, limiter les accès entrants/sortants, réduire la portée d'une compromission.

2. Pourquoi les pare-feu sont-ils utilisés pour bloquer certains ports ?

Les ports représentent des points d'entrée applicatifs ; bloquer les ports non nécessaires réduit la surface d'attaque, applique le principe du moindre privilège et empêche l'utilisation de services non autorisés.

3. Quelle est la différence entre ACL et règles de filtrage ?

ACL (Access Control List) = structure de contrôle (liste de conditions IP/port/action).
« Règles de filtrage » = politique opérationnelle appliquant ACL, états de connexion, time-ranges, QoS ou inspection applicative ; l'ACL est souvent l'élément technique d'une règle.

4. Quels malwares et leur fonctionnement ?

- Virus : s'attache à un hôte/fichier et se propage à l'exécution.
- Ver : se propage automatiquement sur le réseau sans hôte porteur.
- Cheval de Troie (Trojan) : se fait passer pour légitime pour obtenir accès.
- Ransomware : chiffre les données et exige une rançon.
- Spyware/Keylogger : collecte silencieusement données et frappes clavier.
- Adware : affiche publicités indésirables, souvent collecte telemetry.
- Rootkit : masque présence et garde privilèges persistants.
- Botnet : machines compromises contrôlées à distance pour attaques (DDoS, spam).
- Cryptominer : utilise ressources pour miner des cryptomonnaies à l'insu de l'utilisateur.

5. Types de Firewall et solutions sur le marché

Types : packet-filter (stateless/stateful), proxy/application firewall, NGFW (inspection applicative + IDS/IPS), WAF (Web Application Firewall), UTM (fonctionnalités consolidées).

Exemples commerciaux/open-source : Palo Alto, Fortinet (FortiGate), Check Point, Cisco Firepower, Juniper SRX, pfSense / OPNsense.

6. Est-ce qu'un proxy est un IDPS ?

Non. Un proxy filtre/contrôle le trafic applicatif (URL, contenu, auth) ; un IDPS détecte et/ou bloque des intrusions basées sur signatures ou anomalies. Ils sont complémentaires mais distincts.

7. Un pare-feu est-il un IDS ou un IPS ?

Pas nécessairement : un pare-feu applique des politiques d'accès (IP/port/état). Certains pare-feu modernes (NGFW) intègrent des fonctions IDS/IPS pour détection et blocage inline, mais un firewall classique /= IDS/IPS.

8. Que peut détecter un IDS ?

Scans de ports, tentatives d'exploit connues (signatures), comportements anormaux (trafic inhabituel, exfiltration), brute-force, attaques applicatives, anomalies de protocole et indicateurs de compromission corrélés via logs.

9-Un IPS peut-il empêcher les DDoS ? Comment ?

Oui, un IPS peut atténuer les DDoS via : rate limiting (limiter le nombre de connexions/paquets), détection de patterns DDoS (flood SYN/UDP), blocage automatique des IP sources malveillantes, analyse comportementale pour identifier trafic anormal et intégration avec des solutions anti-DDoS externes.

10- Qu'est-ce qui est le mieux ? VPN ou proxy ?

Dépend du besoin : VPN chiffre tout le trafic entre client et réseau (sécurité globale, accès distant sécurisé) ; proxy filtre/contrôle le trafic applicatif (web, Cloud) avec inspection et DLP. Souvent utilisés ensemble pour une sécurité renforcée.

RESSOURCES

- **Documentation pare-feu pfSense** : <https://docs.netgate.com/pfsense/en/latest/>
- **Guide Squid Proxy** : <http://www.squid-cache.org/Doc/>
- **OWASP Secure Configuration Guide** : <https://owasp.org/www-project-secure-configuration-guide/>
- **NIST SP 800-41 Rev. 1 - Guidelines on Firewalls and Firewall Policy** : <https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-41r1.pdf>
- **CIS Controls v8** : <https://www.cisecurity.org/controls/cis-controls-list/>
- **RFC 2827 - Ingress Filtering for Multihomed Networks** : <https://tools.ietf.org/html/rfc2827>
- **ISO/IEC 27001 - Information Security Management** : <https://www.iso.org/isoiec-27001-information-security.html>